

Overview

Part 14 —  AI Compliance · 14-ai-compliance/README.md

Module 14 — AI Compliance

Where you are: Stop 14 of 16. **Time:** ~15 hours · **Prereq:** Module 12 — AI Governance [12-ai-governance] (the internal policy muscle this module points outward). Module 13 — AI Security [13-ai-security] is a useful sibling, not a hard prereq.

Module 12 asked "have we decided, internally, how we build and run AI responsibly?" This module asks a different question: "**does what we do satisfy specific external laws and standards, and can we prove it to someone who doesn't work here?**" Governance is your operating model; compliance is what a regulator, an auditor, or a plaintiff's lawyer checks against a written rule. You need both, and good engineering practice — the model cards, eval reports, and audit trails from Modules 12 and 15 — is the raw material for both.

A warning before you read a word further: this is the module most likely to be wrong by the time you read it. Regulatory text ages in months, not years, and 2026 alone produced a full rewrite of the EU AI Act's timeline, a Colorado law that was passed, delayed, and rewritten twice, and a federal executive order attempting to preempt state AI law entirely. Every date and status claim below is marked with when it was last verified. Re-verify anything load-bearing before you rely on it in a real compliance decision, and read [notes/03](#) [14-ai-compliance/notes/03-building-a-compliance-program.md] on *how* to re-verify it yourself.

This is not legal advice. Nothing in this module — least of all the code — substitutes for counsel qualified in your jurisdiction and sector. Treat it as the technical fluency that makes a conversation with a lawyer productive instead of a translation exercise.

Learning objectives

1. Explain the EU AI Act's risk-tier structure (prohibited / high-risk / limited-risk / minimal-risk) and the separate general-purpose-AI-model track, with concrete examples of what lands in each tier.
2. State the EU AI Act's phased timeline accurately as of your reading date, including which obligations are already in force and which have been delayed — and know where to check for the next change.
3. Describe the US approach as a sectoral patchwork (state laws, FTC enforcement, sector regulators) rather than a single framework, and name the specific mechanism (executive order, state statute, agency guidance) behind any claim you make about it.
4. Map an AI use case's sector-specific obligations: HIPAA + FDA for healthcare, SR 11-7/SR 26-2 + fair lending for finance, bias-audit laws for employment.
5. Explain how GDPR (lawful basis, Article 22, data minimization) and other data-protection law apply specifically to AI systems, including RAG and agents that process personal data.

6. Compare ISO/IEC 42001 and SOC 2 as certifiable/auditable evidence regimes, and use one governance artifact to satisfy multiple frameworks at once.
7. Run a gap assessment: map your AI use cases against applicable regulations by jurisdiction and sector, and know what to bring to — versus expect from — legal counsel.

Suggested path

#	Do this	File	Time
1	The regulatory landscape (EU + US)	notes/01-regulatory-landscape.md	3h
2	Sector rules, data protection, standards, IP	notes/02-sectors-data-protection-and-standards.md	3h
3	Building a compliance program	notes/03-building-a-compliance-program.md	2h
4	Risk-tier classifier tool	code/eu_ai_act_risk_classifier.py	1.5h
5	Documentation-mapping tool	code/compliance_documentation_mapper.py	1h
6	Slides	slides/	1h
7	Lab	lab/EXERCISES.md	4h
8	Papers & primary sources	papers/PAPERS.md	3h

The 18 terms you must own

risk-based tiering · unacceptable/prohibited practice · high-risk system · GPAI model · systemic risk · conformity assessment · technical documentation · notified body · NIST AI RMF · ISO/IEC 42001 · SOC 2 · Article 22 (GDPR) · data minimization · algorithmic bias audit · model risk management (SR 11-7 / SR 26-2) · fair lending / ECOA · training-data fair use · open-weights license

Exit check

Given a real (or realistic) AI use case, you can produce a one-page gap assessment: which jurisdictions and sectors apply, which regulatory tier and obligations follow (EU AI Act tier, applicable US state/sectoral rules, data-protection posture), which existing artifacts (model card, eval report, audit log) already cover which requirement, what's actually missing, and what you'd ask a lawyer to confirm before shipping.